Oopsie

Plataforma: TryHackMe

Dificuldade: Fácil

Autor: Matheus Cruz

Data de Resolução: 12 de abril de 2026

Sumário

1 Visão Geral **2**

2 Reconhecimento **2**

3 Exploração **3**

4 Escalada de Privilégios **4**

5 Conclusão **5**

6 Referências **5**

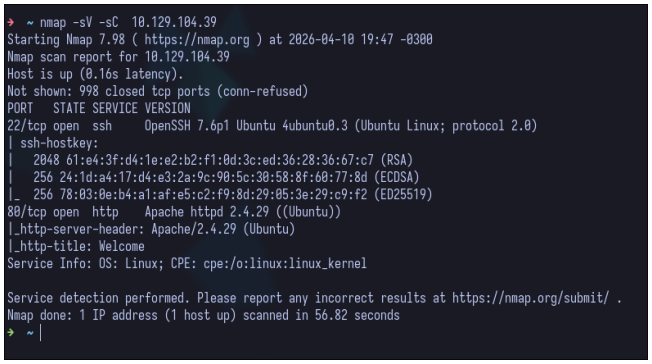
1 Visão Geral

A máquina Oopsie é focada em enumeração web básica e falhas lógicas de controle de acesso. O ataque consistiu em encontrar um painel de login escondido no código fonte, explorar uma vulnerabilidade para elevar privilégios para Super Admin, realizar o upload de um shell reverso em PHP e finalizar com escalada para root abusando de um binário SUID vulnerável a PATH Hijacking.

2 Reconhecimento

Iniciei a máquina rodando um escaneamento padrão com o Nmap para descobrir quais portas estavam abertas e os serviços em execução.

```
nmap -sV -sC <TARGET_IP>
```



```
→ ~ nmap -sV -sC 10.129.104.39
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-10 19:47 -0300
Nmap scan report for 10.129.104.39
Host is up (0.16s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 61:e4:3f:d4:1e:e2:b2:f1:0d:3c:ed:36:28:36:67:c7 (RSA)
|   256 24:1d:a4:17:d4:e3:2a:9c:90:5c:30:58:8f:60:77:8d (ECDSA)
|_  256 78:03:0e:b4:a1:af:e5:c2:f9:8d:29:05:3e:29:c9:f2 (ED25519)
80/tcp open  http    Apache httpd 2.4.29 ((Ubuntu))
|_http-server-header: Apache/2.4.29 (Ubuntu)
|_http-title: Welcome
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 56.82 seconds
→ ~
```

Figura 1: Varredura inicial do Nmap revelando portas 22 (SSH) e 80 (HTTP).

- **-sC**: usa os scripts padrões do Nmap.
- **-sV**: lista informações sobre as versões dos serviços rodando nas portas abertas.

Ao acessar pelo navegador, me deparei com a página de uma empresa automotiva (Megacorp). Inspecionando o código fonte da página inicial (HTML), encontrei um diretório escondido apontando para `/cdn-cgi/login`. Acessando esse link, cheguei no painel de autenticação.

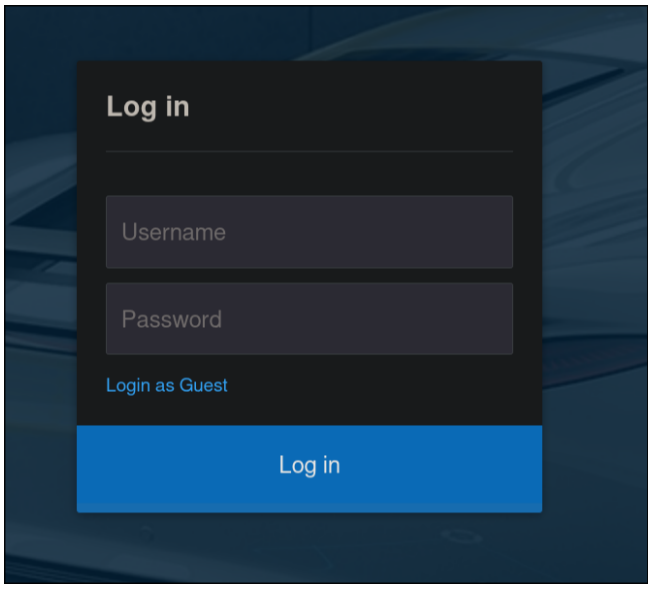


Figura 2: Login

3 Exploração

Utilizando credenciais de acesso básico (`guest`), consegui logar no sistema. O painel não me dava muitas opções, mas ao navegar para a aba de conta, notei que a URL (ou os cookies da sessão) passava um parâmetro de ID de usuário.

Como eu estava logado como *guest* (id=2), testei alterar o valor do meu ID para 1. Para minha alegria, após atualizar a página, o sistema me validou como **Super Admin**.

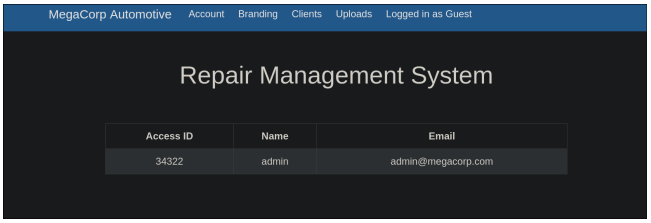


Figura 3: Painel liberado após alterar o ID do usuário.

Ao retornar à página de uploads, o browser atualizava novamente meu ID para o guest. Para tentar contornar isso, alterei o usuário salvo no cookie local para os valores encontrados em 3. Com isso, pude acessar o painel de uploads como admin:

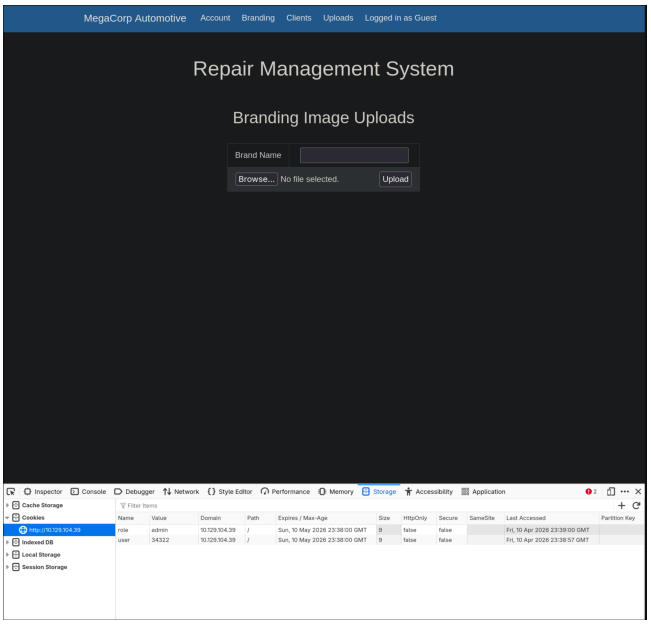


Figura 4: Painel de uploads como admin

Com a possibilidade de enviar arquivos, tentei submeter um arquivo PHP extraído de [1] para a criação de um shell reverso. Após o upload, não era indicado o caminho onde esses arquivos eram salvos, mas, por sorte, iam para `/uploads`. Após localizar meu arquivo e confirmar que ele era executado, criei um listener local com o Netcat:

```
nc -lvnp 4444
```

- **-l**: (*listen*) coloca o Netcat em modo de escuta.
- **-v**: (*verbose*) exibe os detalhes da conexão na tela quando ela ocorrer.
- **-n**: (*numeric*) evita a resolução de DNS, trabalhando apenas com IPs para agilizar o processo.

- **-p**: define a porta local (4444) que será aberta.

E então executei o script, obtendo acesso à máquina.

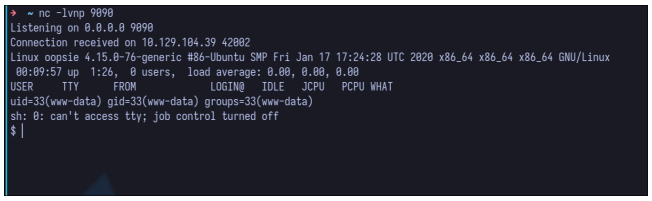


Figura 5: Acesso inicial recebido via reverse shell em PHP.

4 Escalada de Privilégios

Como `www-data`, minhas permissões eram limitadas. Em buscas iniciais com *sudo -l* e SUIDs, não encontrei nada interessante. Vasculhando os arquivos na pasta **/var/www**, encontrei algo interessante: o arquivo `db.php` continha um usuário e senha salvos em texto claro. Testei esse usuário e senha com o comando **su robert**, conseguindo acesso a uma nova conta.

Como `robert`, encontrei uma nova aplicação rodando com bit SUID que poderia ser um ponto de entrada: **bugtracker**. Após rodar essa aplicação, notei que ela chamava o comando cat (como root), sugerindo a possibilidade de **PATH Hijacking**. Criei um arquivo chamado cat dentro de **/tmp** que gerava um shell como root e adicionei o diretório ao início da variável PATH, de modo que a minha versão do cat fosse a primeira a ser encontrada:

```
echo '/bin/sh' > /tmp/cat
chmod +x /tmp/cat
export PATH=/tmp:$PATH
```

Ao executar o **bugtracker** novamente, consegui acesso a um novo shell como root.

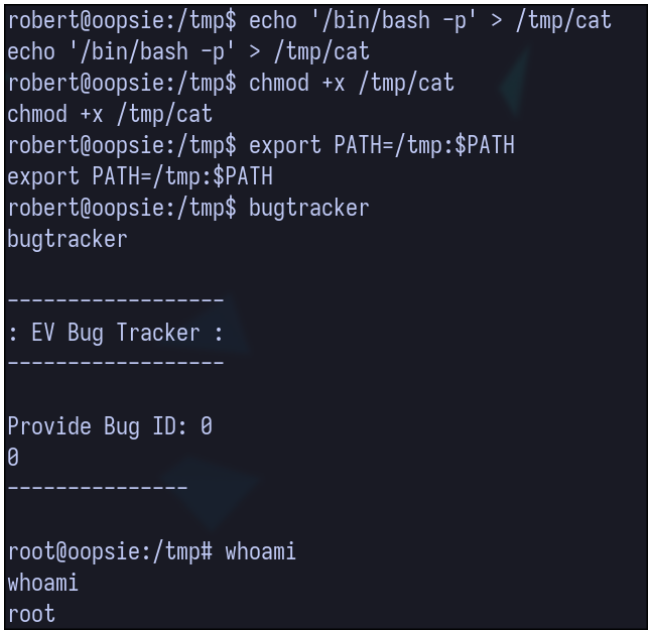


Figura 6: Shell root

A partir daí, foi possível extrair a última flag e finalizar o CTF.

5 Conclusão

A falta de validação em cookies/IDs do lado do servidor permitiu um IDOR trivial, e a má prática de não utilizar caminhos absolutos (*absolute paths*) em scripts e binários com privilégios elevados resultou no comprometimento total da máquina.

6 Referências

Referências

[1] Reverse Shell Generator. Acesso em: 12 de abril de 2026.